

QUICK REVISION PLAN — GRC (Cybersecurity)

1 Core ISO Standards to Remember

Focus on the *purpose* and *scope* of each — you’ll likely get questions like “Which ISO standard focuses on...?”

Standard	Focus Area	Key Points
ISO/IEC 27001	Information Security Management System (ISMS)	Establishes, implements, maintains, and improves ISMS. Risk-based approach to confidentiality, integrity, availability.
ISO/IEC 27002	Code of practice for ISMS controls	Guidance and best practices for implementing controls in 27001 Annex A.
ISO/IEC 27005	Risk Management	Focuses on identifying, assessing, and treating information security risks.
ISO 31000	Enterprise Risk Management	Broad risk management principles (not just info security). Framework: <i>Establish context</i> → <i>Assess</i> → <i>Treat</i> → <i>Monitor</i> → <i>Communicate</i> .
ISO/IEC 27017	Cloud Security Controls	Additional security for cloud service providers and customers.
ISO/IEC 27018	Protection of PII in Cloud	Focuses on privacy and personal data in cloud environments.
ISO/IEC 22301	Business Continuity Management	Ensures organizations can continue operations during disruptions.
ISO/IEC 27701	Privacy Information Management System	Extends 27001/27002 to cover data privacy and GDPR alignment.

□ *Tip:* Remember **27001** = **System**, **27002** = **Controls**, **27005** = **Risks**, **31000** = **Enterprise Risk**, **22301** = **Continuity**.

2 Key GRC Concepts & Principles

Governance:

- Strategic direction, policies, accountability, oversight.
- Frameworks: COBIT, ISO 38500 (Corporate Governance of IT).

Risk Management:

- Identify → Analyze → Evaluate → Treat → Monitor → Communicate.

- Risk Types: operational, compliance, reputational, strategic, financial.
- Control types: Preventive, Detective, Corrective.

Compliance:

- Meeting legal, regulatory, and contractual obligations (e.g., GDPR, HIPAA).
- Involves internal audits, monitoring, reporting, and policy enforcement.

3 📌 Cyber Risk Formulae You Should Know

Formula	Meaning
Risk = Threat × Vulnerability × Impact	Basic risk expression (qualitative).
Risk = Likelihood × Impact	Most used quantitative model.
Annualized Loss Expectancy (ALE) = SLE × ARO	ALE = expected yearly loss.
SLE (Single Loss Expectancy) = Asset Value × Exposure Factor	One-time financial loss per incident.
ARO (Annual Rate of Occurrence)	Estimated frequency of the event per year.
ROI (Return on Investment) = (Benefit – Cost) / Cost × 100%	Used to justify security spending.
Residual Risk = Inherent Risk – Control Effectiveness	Remaining risk after controls.

❑ *Tip:* If the question says “how often,” think **ARO**; if it says “per incident,” think **SLE**.

4 📌 Quick-Fire Revision Reminders

- ✓ **CIA Triad:** Confidentiality, Integrity, Availability.
- ✓ **Defense in Depth:** Multiple layers of security.
- ✓ **PDCA Cycle (from ISO 27001):** Plan → Do → Check → Act.
- ✓ **Risk Treatment Options:** Avoid, Transfer, Mitigate, Accept.
- ✓ **Control Types:** Administrative, Technical, Physical.
- ✓ **Compliance Tools:** Policies, Procedures, Audits, Monitoring.

❑ GRC CYBERSECURITY – QUICK REVISION CHEAT SHEET

◆ ISO STANDARDS (Know Their Focus)

ISO / IEC	Focus	Key Idea
27001	ISMS (Information Security Management System)	Framework for managing information security (Plan-Do-Check-Act).
27002	Controls & Best Practices	Guidance for implementing Annex A controls from 27001.
27005	Risk Management	Identify, assess, and treat information security risks.
31000	Enterprise Risk Management	Organization-wide risk framework (Context → Assess → Treat → Monitor).
27017	Cloud Security	Security controls for cloud service providers/customers.
27018	Cloud Privacy / PII	Protects personal data in cloud environments.
22301	Business Continuity	Keep operations running during disruptions.
27701	Privacy Information Mgmt	Extension of 27001/27002 for data privacy & GDPR.

□ *Memory tip:*

27001 = System | 27002 = Controls | 27005 = Risks | 31000 = Enterprise Risk |
 22301 = Continuity

◆ CORE GRC PRINCIPLES

Governance: Strategy · Policies · Accountability · Oversight

Risk Management: Identify → Analyze → Evaluate → Treat → Monitor → Communicate

Compliance: Adhere to laws / standards / contracts (e.g., GDPR, HIPAA)

Frameworks: COBIT · ISO 38500 · NIST RMF

Control Types: Preventive · Detective · Corrective

◆ RISK & SECURITY FORMULAE

Formula	Meaning
Risk = Threat × Vulnerability × Impact	Qualitative expression of risk.
Risk = Likelihood × Impact	Quantitative model.
SLE = Asset Value × Exposure Factor	Single-loss cost per event.

Formula	Meaning
ALE = SLE × ARO	Annualized expected loss.
Residual Risk = Inherent Risk – Control Effectiveness	Risk left after controls.
ROI = (Benefit – Cost) / Cost × 100 %	Return on security investment.

💡 *Keywords:*

SLE → One incident | ARO → How often per year | ALE → Total annual loss

◆ QUICK SECURITY BASICS

- **CIA Triad:** Confidentiality | Integrity | Availability
- **Defense in Depth:** Multiple layers of security controls.
- **PDCA Cycle (ISO 27001):** Plan → Do → Check → Act.
- **Risk Treatment:** Avoid · Transfer · Mitigate · Accept.
- **Control Categories:** Administrative · Technical · Physical.